T. pradeepa

Reg no : 192126 0280

SIMATS ENGINEERING

SIMATS

Saveetha Institute of Medical And Technical Sciences

(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

I 192126 0280 Pradeepa. T *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

Question 1

NO, I would not exploit the vulnerability without proper authorization from the company.

Ethical hacking must be performed only with permission and within the agreed scope. If I discover a critical vulnerability in a scope that is not included in the authorization, I would stop testing that system and inform the company about the issue

I would explain the possible risks of the vulnerability and request written permission before performing any further testing. I would also document the findings and keep the information confidential

This follows the principles of authorization, confidentially, responsible disclosure and avoiding harm, Exploiting the vulnerability without permission could cause damage to the system and lead to legal problems

conclusion: I would report the vulnerability and obtain proper written authorization before testing it. This ensures that the testing is safe, legal and ethical

Question 2

I would avoid exploiting the SQL injection vulnerability in a way that could expose or damage real customer financial data. I would inform the client about the vulnerability and obtain permission before proceeding with further testing

To avoid causing harm, I would take the following steps

1. Inform the client: Report the vulnerability and explain the risks the customer care
2. Avoid Accessing sensitive: Do not view, copy, modify or delete real customer information.
3. Use a Test Environment: Perform further testing in a safe environment with dummy data, if possible
4. Obtain permission: Get approval from the client before continuing the testing
5. Maintain confidentiality: keep all customer information secure and report the findings only to authorized people

Conclusion: Ethical hackers must protect customer information and prevent damage to systems, proper planning, authorization and safe testing methods help ensure that penetration testing is ethical and secure

Question 3

During a black-box penetration test, accidentally causing a denial of service condition can interrupt the client's services, As an ethical hacker, I must take responsibility for the incident and minimize the damage

Prevention:

1) plan the testing properly and identify risks
2) Follow the agreed scope and rules
3) Avoid risky tests without proper approval

Responsibilities After the Incident:

1) Stop testing immediately
2) Inform the client about the outage
3) Help the IT team restore services
4) Document the incident and take steps to prevent it from happening again

Conclusion: An ethical hacker must act responsibly, report problems immediately and help restore normal operations

Question 4

If a client asks me to test their systems without informing the IT department, it can create ethical and pratical risks. The IT team may mistake the testing activity for a real cyberattack, leading to confusion or unneccessary action.

Risks:

1. The IT team may misunderstand the test as an actual attack
2. Testing may accidentally disrupt services
3. There may be legal issues if proper authorization is not obtained:

Pre cautions:

1. Obtain written authorization from the client
2. Clearly define the scope and rules of engagement
3. Establish an emergency contact to handle unexpected problems
4. Agree on how to stop testing if serious issues occur

conclusion: A penetration test must have proper authorization, clear rules and emergency procedures to ensure safe and ethical testing

Question 5

A red team exercise and a vulnerability assessment are used to test an organization's security, but their approaches are different.

1, Red team Exercise:

A bank hires a red team to test its physical and digital security. The team simulates real world attacks, such as attempting to enter restricted areas or testing security system, within the approved scope

2, Vulnerability Assessment:

The bank hires security experts to identify weaknesses in its systems, networks and applications They prepare a report listing the vulnerabilities and suggest solutions to fix them

Ethical principles:

Both activities require written authorization, a clearly defined scope, confidentiality and rules to prevent damage.

conclusion: A red team exercise tests the bank's ability to detect and respond to attacks, while a vulnerability assessment identifies security weaknesses and recommends solutions